

DROS: 針對自主 AI 工作負載中「Agent 至執行歸因治理」的四層確定性執行期作業基板 (v4.0)

多階段自主 AI 黑客紅隊對抗評測與嚴謹可重現性藍圖

陳濬程 (Chun-Cheng / Jimmy Chen)
康宸園有限公司 (Top-Celestial Company Ltd.)
台灣台北市
jimmychen@dr-os.io

Abstract—在自主 Agent 工作負載中，AI 模型被賦予多步驟工具調用權限以直接操作企業後端系統。然而，現有防禦機制面臨嚴重的結構性缺陷——「Agent 至執行之歸因鴻溝 (Agent-to-Execution Attribution Gap)」：應用層中介軟體（如提示詞防火牆、JSON 架構攔截器）本質上屬於機率性機制，缺乏確定性的執行邊界約束；而作業系統層級的原語（如 eBPF、Seccomp）則對使用者空間的 Agent 角色「上下文盲目 (Context-Blind)」，無法在二進位層級區分系統呼叫的業務發起者。

為解決此一挑戰，本文提出 DROS 四層確定性執行期作業基板 (Deterministic Runtime Operating Substrate)。DROS 確立了四個清晰的架構職責：L1 偵測 (Detect)、L2 歸因 (Attribute)、L3 約束資料 (Constrain Data) 與 L4 強制執行 (Enforce Execution)。DROS 透過在二進位 C-ABI / FFI 邊界強制執行零信任權限點陣圖，提供微秒級決策延遲（端到端決策中位數 26.1 μ s，經由無鎖 RCU 實現 420 ns 狀態指標切換延遲——與端到端網路延遲明確區隔——以及 <500 ns 熔斷延遲），並生成支援監管透明度與可追溯性目標（如歐盟 AI 法案透明度要求）的 Ed25519 簽名可驗證審計存證鏈。

本文呈現了一套完整的四階段自主 AI 紅隊對抗評測 (Autonomous Adversarial Evaluation)，導入頂級自主 AI 滲透黑客平台 Strix (v1.5.3) 進行連續實機攻防，在 6 萬次以上 HTTP/協定探針 ($N_{probe} > 60,000$) 中分配了 38.48M LLM Tokens 的自適應推理預算。實證評測成果顯示：(1) 周界校準基準 (Stage 1)：Strix 成功利用發生於 DROS 治理邊界外的獨立部署漏洞（/.git 目錄暴露，CVSS 7.5 高危）還原原始碼庫，客觀確立攻擊者未受人為約束，具備真實滲透破壞力；(2) 白盒自適應攻擊 (Stage 2)：攻擊者在獲取完整原始碼與 OpenAPI 架構下，消耗 21.4M Tokens 推理預算對 DROS 策略閘門發起自適應 Exploit Chaining ($N_{exec-attempt, S2} = 2,410$)，受測語料庫中到達網關邊界的所有未授權探針全數被拒絕；(3) 信任邊界內真機治理 (Stage 3)：在具備明確能力的合法 Agent 憑證環境下，Strix 發起工具參數逃逸 ($N_{exec-attempt, S3A} = 700+$)、動態資訊流控制 (IFC) 業務資料脫罩 ($N_{IFC} = 203$ 種排列組合) 與並發 Token 重放 ($N_{exec-attempt, S3C} = 120$)。DROS 動態遮蔽於帶內 100% 替換受測語料庫中的專利配方 ($N_{raw-secret-exposure} = 0$)，RCU 原子撤銷以 420 ns 狀態指標切換延遲截斷重放執行（在所有受測案例中未觀察到任何重放執行）；(4) 執行期底座最終兜底 (Stage 4)：在所有受測的對抗向量下，DROS 均嚴格維持形式化安全不變量：

$$C_A \not\Rightarrow C_E \quad (1)$$

$$C_A \wedge \neg C_E \implies I_{physical} = 0 \quad (2)$$

在所有與執行相關的對抗嘗試中 ($N_{exec-attempt} = 3,433$)，未授權物理執行次數嚴格維持為 $N_{unauth-exec} = 0$ 。

專利聲明：DROS 執行治理與安全技術已申請美國臨時專利保護 (U.S. Patent Application No. 64/111,973 · Patent Pending)。

Index Terms—AI Agent 安全、執行期作業基板、C-ABI 邊界強制約束、自主對抗性評測、RCU 即時熱撤銷、動態資訊流控制 (IFC)、歸因治理。

I. 引言與語義-內核悖論

當自主 AI Agent 具備合法憑證、OAuth 會話 Token 與資料庫連線權限時，在已驗證身分的應用層濫用情境下，傳統周界控制單獨運作顯然不足，因為惡意行為係來自經認證的內部實體。

A. 語義-內核悖論

現代系統文獻指出了 AI 防禦機制的根本分裂：

- 1) 語義應用中介軟體 (高語義，零確定性)：提示詞防火牆、JSON 模式驗證器與應用中介（如 Microsoft AGT）能理解自然語言與宣告架構。然而它們缺乏執行邊界約束力；一旦攻擊者利用直譯器逃逸 (eval、bash) 或未宣告路徑，此類應用層策略即告失效。
- 2) 內核沙盒機制 (高確定性，零語義)：OS 底層機制（如 Seccomp、Linux Namespaces、eBPF）能強制執行二進位系統呼叫規則，但無法識別同一個 Worker 行程中的資料庫連線是由合法的財務 Agent 還是被劫持的客服 Agent 所發起。

B. DROS 四層基板物理架構定位與核心設計主張

DROS 介於上層應用框架與底層作業系統之間，確立四層深度防護（L1 機率性偵測可能失效，但 L2–L4 確定性強制約束）：

Guardrail 約束 Agent「可能做什麼」；DROS 約束 Agent「確定被允許執行什麼」。

II. 威脅模型：AGENT 執行期攻擊向量 (AAV-2026)

我們將針對 Agent 執行控制面的攻擊手法正規化為 Agent 攻擊向量 (AAV-2026)：

- AAV-1 (間接提示注入)：外部不可信資料中潛藏的惡意指令劫持推理決策 (MITRE ATLAS AML.T0051)。
- AAV-2 (未宣告工具與直譯器逃逸)：攻擊者利用程式碼直譯器 (eval、exec、bash) 繞過宣告的 JSON Schema (AML.T0053)。
- AAV-3 (業務邏輯誘騙與資料去識別化)：合法查詢透過邏輯操弄誘騙 Agent 輸出商業機密 (ESPR 破護照配方、專利參數，AML.T0054)。

- **AAV-4 (Token 重放與撤銷競爭)**：攻擊者在分散式撤銷清單傳播完成前，大量並發重放已作廢或過期的能力 Token (AML.T0040)。
- **AAV-5 (突破後白盒自適應橫移)**：攻擊者取得完整倉庫原始碼與 OpenAPI 架構後，量身打造自適應繞過鏈 (AML.T0010)。

III. DROS 四層架構形式化規範

A. L1: 偵測情報層 (Detect)

L1 負責在入口端過濾已知攻擊字串與提示詞越獄特徵。L1 定位為前置過濾器而非可信邊界。

B. L2: 身分與零信任網絡層 (Attribute)

所有工具調用必須附帶由三層 PKI 簽署的 **DrosIdentityToken (DIT)**：

$$DIT = \text{Sign}_{K_{\text{BEC}}} \left(\text{Principal_ID} \parallel \text{Role} \parallel \text{Epoch} \parallel \text{Capability_Mask} \right) \quad (3)$$

GuardVM 內核在二進位層級驗證 Ed25519 簽名，在評估權限前為使用者空間 Agent 與執行期動作建立顯式的執行歸因綁定。

C. L3: 動態資訊流控制 (Constrain Data)

L3 實施細粒度資料來源追蹤與動態污點標記。當 Agent 查詢敏感資料 (如 ESPR 數位產品護照) 時，L3 自動於帶內進行遮蔽：

$$\text{Payload}_{\text{out}} = \mathcal{T}_{\text{mask}}(\text{Payload}_{\text{raw}}, \text{Taint_Policy}) \quad (4)$$

專利配方與機密參數被強制替換為零知識承諾或遮蔽佔位符 ([REDACTED_BY_DROS_POLICY_GATE])。

D. L4: 實體執行強制層 (Enforce Execution)

L4 在系統初始化時將授權規則編譯為不可變的 $O(1)$ 數值點陣圖：

$$\text{Decision} = \text{Capability_Bitmap}[\text{Role_ID}] \& \text{Requested_Tool_Bit} \quad (5)$$

若未授權，執行流在 C-ABI 邊界於 **<500 ns** 內物理中斷。無鎖 RCU 切換原子指標之狀態指標切換延遲為 **420 ns** (與端到端請求拒絕延遲明確區隔)，作廢 Token 在微秒內即刻失效。

IV. 多階段自主 AI 黑客紅隊對抗實測

為杜絕傳統「預設答案」的偽測試，我們導入由前沿推理大模型 (gemini-3.6-flash) 驅動的 **Strix (v1.5.3)** 自主 AI 滲透黑客戰隊。Strix 展現自適應對抗搜尋特性，在四個漸進階段中分配了 **38.48M Tokens** 與 $N_{\text{probe}} > 60,000$ 次 HTTP/協定探針。

A. 階段一：周界校準基準 (攻擊者實戰能力驗證)

Strix 對目標環境發起無約束黑盒掃描。利用 ffuf 路由探測，Strix 發現了暴露的 /.git/ 倉庫目錄，並自主調用 git-dumper 完整重建了 164 個子目錄下的 270 個 Git 物件與原始碼 (CWE-538, CVSS 7.5 High)。架構範疇與方法論意義：/.git 目錄暴露係屬於發生於 DROS 邊界外 (L1 之前) 的 Web 伺服器獨立部署配置缺陷。Strix 成功攻破此弱點，客觀證實攻擊者具備真實破壞力，而非人為約束以產出預設的 DROS 防禦結果。

B. 階段二：白盒自適應攻擊

在取得完整原始碼與 OpenAPI 架構後，Strix 晉升為白盒攻擊者，分配 **21.4M Tokens** 針對 DROS Policy Gate 構造自適應 Exploit Chaining，產生 $N_{\text{exec-attempt}, S2} = 2,410$ 次結構化執行探測。結果：在受測攻擊語料庫中，所有到達 DROS 策略邊界的未授權探針全數被確定性阻斷 (HTTP 444 / 403)，攻擊無法轉化為實體執行。

C. 階段三：信任邊界內真機對抗與受陷後評測

在具備明確能力設定的合法 Agent 環境下進行評測：

- **實體配置**：principal: "agent-eval-01", role: "Auditor", authorized: ["telemetry", "espr_summary"], prohibited: ["exec_shell", "raw_bom"]。
- **工具調用介面 (/api/v1/agt/invoke_tool)**：Strix 測試了 $N_{\text{exec-attempt}, S3A} = 700+$ 組工具名稱與架構逃逸參數。在受測威脅模型下，後端 Handler 未觀察到任何成功的直譯器逃逸或未宣告工具執行。
- **DROS 動態隱私閘門 (/api/v1/dros/query_espr_data)**：Strix 構造了 $N_{\text{IFC}} = 203$ 種查詢組合嘗試提取商業配方。DROS 資訊流控制 (IFC) 動態攔截所有嘗試，機密欄位全數被替換為遮蔽佔位符 ($N_{\text{raw-secret-exposure}} = 0$)。
- **DROS 即時熱撤銷閘門 (/api/v1/dros/execute_revoked_action)**：Strix 針對已作廢 Action 發起 $N_{\text{exec-attempt}, S3C} = 120$ 次並發重放。DROS RCU 狀態指標切換延遲為 **420 ns** (0 / 120 次重放嘗試執行)。

D. 評測範疇與主張邊界

本文回報之零未授權執行結果 ($N_{\text{unauth-exec}} = 0$)，嚴格受限於已實作的 DROS 強制執行邊界、受評測威脅模型、受測協定介面以及本次活動中執行的對抗語料庫。該結果不應被詮釋為在任意部署或未建模實作中普遍不存在漏洞的數學證明。

V. 定量評測與資源分配

A. 延遲與效能開銷

- **端到端策略決策延遲 (P50 / P99)**：26.1 μs / 31.4 μs
- **L4 二進位熔斷延遲**：< 500 ns (0.42 μs)
- **RCU 狀態指標切換延遲**：420 ns (原子指標切換開銷)
- **每 Agent 會話記憶體開銷**：1.8 KB (決策路徑零堆疊分配)

VI. 相關工作與架構對照

VII. 結論與安全不變量

本文提出了 **DROS 四層確定性執行期作業基板** 的架構規範與多階段實機對抗評測。DROS 提供確定性的執行強制機制，並透過自主反例驅動對抗搜尋對其安全不變量進行驗證；在本研究所涵蓋的狀態空間與攻擊搜尋空間中，未觀察到任何可執行之反例。

基於 **Strix** 的紅隊評測確立了兩大核心結論：

- 1) **對抗真實性與 DROS 邊界**：Strix 成功攻破發生於 DROS 邊界外的周界缺陷 (/.git 洩漏)，證明紅隊具備真實破壞力，絕非打假球。

TABLE I
全譜系多階段紅隊對抗評測實測矩陣 (STRIX v1.5.3)

評測階段	攻擊者手法 (Strix v1.5.3)	推理預算 / 探針數量	受測治理層級	執行嘗試數 ($N_{\text{exec-attempt}}$)	觀測到的防禦效果	物理執行影響
階段一：周界校準	60,000+ Fuzzing / git-dumper	16.2M Tokens (\$2.97)	Web 部署根目錄 (DROS 邊界外)	不適用 (部署缺陷)	[!] /.git 被提取 (CVSS 7.5)	原始碼洩漏
階段二：白盒自適應	自適應 Exploit Chaining	21.4M Tokens (\$3.30)	DROS 網關策略	$N_{S2} = 2,410$	[*] 網關邊界全數拒絕	0 位元組影響
階段三 A：工具邊界	700+ 工具名稱變異 / Schema 逃逸	子 Agent c4e12592	工具調用 Handler	$N_{S3A} = 700+$	[*] 維持 Schema 邊界	0 逃逸執行
階段三 B：資料污點	$N_{\text{IFC}} = 203$ 排列組合	子 Agent f3cff207	DROS L3 動態 IFC	$N_{S3B} = 203$	[*] 100% 帶內即時遮蔽	$N_{\text{raw-secret}} = 0$
階段三 C：即時撤銷	並發 Token 重放 / Nonce 探針	Token Burst 引擎	DROS L4 RCU 指針	$N_{S3C} = 120$	[*] 420ns 指標切換延遲	0 重放執行
階段四：最終兜底	二進位 Syscall 審計	38.48M 總 Tokens	DROS 二進位作業基板	總數 $N_{\text{exec-attempt}} = 3,433$	[*] 一致性維持強制執行不變量	$N_{\text{unauth-exec}} = 0$

TABLE II
AGENT 執行治理架構模型橫向對照

治理架構模型	強制執行平面	執行歸因綁定	熔斷延遲	撤銷機制
NeMo Guardrails	應用層 (Python)	無 (僅提示詞)	> 150 ms	無
Microsoft AGT	中介軟體 (Schema)	應用層上下文	5–20 ms	最終一致
Linux Seccomp	內核層 (Syscall)	無 (行程層級)	< 1 μ s	OS 信號
DROS (本研究)	二進位 C-ABI / FFI	三層 PKI (DIT)	<500 ns	420 ns (RCU)

- [4] 陳濬程, “DROS 6P Architectural Specification: Unified Trust, PKI, and Execution Governance,” *Zenodo* 規範手冊, DOI: [10.5281/zenodo.21833970](https://doi.org/10.5281/zenodo.21833970), 2026.
- [5] Strix 安全研究團隊, “Strix: Autonomous Multi-Agent AI Penetration Testing Framework (v1.5.3),” 2026. [Online]. Available: <https://strix.ai>, Documentation: <https://docs.strix.ai>
- [6] 微軟, “Agent Governance Toolkit (AGT): Semantic Middleware for LLM Workloads,” 微軟技術文檔, 2025.
- [7] NVIDIA, “NeMo Guardrails: Programmable Guardrails for LLM Applications,” *NVIDIA* 開發者文檔, 2024.
- [8] 歐洲議會, “歐盟人工智慧法案 (Regulation EU 2024/1689), 第 50 條: AI 系統之透明度與可追溯性要求,” 歐洲聯盟官方公報, 2024.
- [9] MITRE 組織, “ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems,” *MITRE ATLAS* 知識庫, 2026.
- [10] OWASP 基金會, “OWASP API Security Top 10,” *OWASP* 安全標準, 2023/2026.

2) 安全不變量與授權非繼承性 (Non-Inheritance)：即使自主 AI 黑客達成應用層受陷並獲取完整原始碼，執行授權絕不會被自動繼承：

$$C_A \not\Rightarrow C_E \quad (6)$$

$$C_A \wedge \neg C_E \Rightarrow \neg \text{Exec}_{\text{unauthorized}} \Rightarrow I_{\text{physical}} = 0 \quad (7)$$

本評測實證展示在 $N_{\text{exec-attempt}} = 3,433$ 次執行嘗試與 38.48M Tokens 的自適應對抗測試下，物理執行層面的未授權執行次數嚴格維持為 $N_{\text{unauth-exec}} = 0$ ($N_{\text{counterexample}} = 0$)，獨立物理狀態差分驗證亦確認 $S_{\text{after}} \equiv S_{\text{before}}$ 。

REFERENCES

- [1] 陳濬程, “DROS: 彌合自主 AI 工作負載中「Agent 至執行歸因鴻溝」的四層確定性執行期作業基板,” *Zenodo* 技術報告, DOI: [10.5281/zenodo.22092008](https://doi.org/10.5281/zenodo.22092008), 2026.
- [2] 陳濬程, “DROS Trilogy Reading Guide: An Agent Runtime Operation Substrate (Academic Version 3.0),” *Zenodo* 技術導讀, DOI: [10.5281/zenodo.22114036](https://doi.org/10.5281/zenodo.22114036), 2026.
- [3] 陳濬程, “DROS-PGM: Physical Guard Module with Sub-Microsecond C-ABI Binary Execution Boundary,” *Zenodo* 研究報告, DOI: [10.5281/zenodo.21903687](https://doi.org/10.5281/zenodo.21903687), 2026.